Campus Companion: Ethics Statement

- **Team Members:** Kaden Sawyer and Laila Raines

Privacy summary

Data item	Source	Purpose	Consent	Storage	Access	Retention
Email and password	Sign-up; confirmed UC emails only	Sign in; prove UC student	Sign-up checkbox for the Terms and Privacy Policy, with a link	Supabase Auth; password hashed	Server; us in the dashboard; admins on club requests	Until account deletion or project end
Login session	Supabase Auth	Stay signed in	Part of signing in	Phone secure storage	That device	Cleared on sign-out; token lasts 1 hour
Consent record	Consent screen	Gates saving courses and interests	"Allow" button	`student` table	Server only	Withdrawal deletes courses and interests; deleted with account
Schedule PDF (I1)	Upload, 10 MB and 5 pages max	Extract courses for review	Told the PDF is read once, then discarded	Not saved; never in the database or logs	Server, during the request	Gone when the request ends
Courses (name, professor, building, room, days, times, dates)	PDF or manual entry, confirmed by student	Walk times (C2), event fit (C3), recognizing courses	"Allow" on the consent screen; saved after Confirm	`course` table	Server only	Deleted on withdrawal, with account, or 30 days after the course ends
Interests, including Cultural and Religious	Onboarding or Settings	Event matching (C3) and notices (C7)	Optional; told no club or student sees them	`student_interest` table	Server only; heads see counts, not names	Deleted when removed, on withdrawal, or with account
Club (name, description, head,	Head's request, admin approval	Only verified clubs post	"Agree" checkbox: checked against	`club`, `club_category`	Server writes; students see the name	With head's account, on request, or

Data item	Source	Purpose	Consent	Storage	Access	Retention
verified date)			Campus Links, kept if verified			after a year without events
Club request (club details, link, decision, admin note)	Club head; admin checks Campus Links (I12)	Manual approval (D-04)	Same "Agree" checkbox	`club_request`	Requester sees status and note; admins also see the email	Pending: 30 days. Denied: 30 days after decision. With requester's account
Event posts (name, place, description, times, status, categories)	Club head (I7b, I9)	Event list, suggestions, notices	"Allow" checkbox: shown to all signed-in students	`event`, `event_category`	Signed-in students	1 week after it ends or is cancelled, or with its club
Push token (token, platform, last seen)	Phone (I13)	Deliver notices	App asks first, then the phone's prompt; off in Settings	`push_device`; via Expo to Apple or Google	Server only	Deleted on sign-out or with account; disabled if invalid
Notice content (title, body, categories) (I11)	Event published or cancelled	Notify interested students	The notification permission	`notification_job`; Expo holds it in memory only	Server only; no recipient list	30 days after sending
Logs (time, request ID, route, status, duration, user ID)	Server (G4) and Supabase	Debugging and security	Stated in the privacy notice at sign-up	Host and Supabase log viewers; emails, tokens, and course data redacted (unit test, EC-63); may include IP addresses	Team members only	Up to 30 days (host chosen to match, Q1)
Map requests (I14)	Map library	Background map	Stated in the privacy notice	None by us; OpenFreeMap sees the map area and IP address, never class data	OpenFreeMap	OpenFreeMap's terms
Volunteer test PDFs (GAP-9)	Volunteers	Test PDF reading	Asked first; told the file is	Our own computers, never committed	Team members only	Deleted when testing ends

Data item	Source	Purpose	Consent	Storage	Access	Retention
			deleted after			
Categories, buildings, paths, walk times (not personal)	GetInvolvedUC list; OpenStreetMap (I5)	Matching and routing	n/a	`category`, `building`, `walk_time`	Server; names shown to users	Updated by migration or map import

- **How consent is obtained:** After sign-up and email confirmation, a consent screen lists what is stored (courses and interests) and why, says the PDF is discarded, and says that withdrawing consent or deleting the account deletes the data. Without "Allow", a student can browse events but cannot save a schedule or interests. Both options stay in Settings.
- **Storage:** All tables are in our Supabase project, encrypted at rest with AES-256, with row-level security and no policies, so only the server's secret key can read them. The free plan keeps no backups (on Pro, deleted rows would stay in backups up to 7 days, and the notice would say so). A daily job on the server applies the time limits above. The app never reads the phone's location.
- **What happens to the data when the project ends:** After the showcase, we delete every real account, which cascades to that student's data, then the remaining events, notices, and logs. We may keep a few fictional accounts for future viewing.
- **Fields removed because we could not justify them:** a list of which students received each notice (R-10), the uploaded PDF itself, and any copy of the schedule on the phone (NFR-02).

Security summary

- **Authentication:** Supabase Auth email and password, confirmed UC emails only. Every request sends `Authorization: Bearer <access token>` over HTTPS. The server verifies it with Supabase and uses the token's user ID, never one from the request.
- **Token lifetime:** Access tokens last 1 hour. Each refresh token works once, and reusing one ends the session.
- **Where secrets live:** The Supabase secret key lives only in the host's environment variables. The server will not start without it and never logs its value. The apps hold only the public key, which row-level security blocks from every table.
- **HTTPS:** The API, Supabase, Expo, and OpenFreeMap are reached only over HTTPS, and the server refuses a non-https `SUPABASE_URL`.
- **Rate limiting:** Supabase Auth limits sign-in and sign-up. Our API has no request limiter yet. Uploads stop at 10 MB, 5 pages, or 8 seconds, a student may have one pending request per club, and Expo sends are capped at 5 batches a second.
- **Git history search results:** Ran gitleaks on all branches on 2026-11-12: 34 commits scanned, no leaks found. The audit found that the `*.env` rule in `.gitignore` misses `.env.local`, `.env.production`, and `.p8` push keys, so we will change it to `.env*` and add `*.p8` when we create the app folders.

Common capstone gap	How we will address it
Default credentials	Unique passwords with two-factor sign-in on the Supabase and hosting dashboards and the admin account; no seeded or shared accounts.
Unauthenticated endpoints	Every API route requires a Supabase access token and returns 401 `not_signed_in` without one. We test each route without a token before release and disable or protect FastAPI's `/docs` routes.

Common capstone gap	How we will address it
Secrets in source control	Secrets live only in the host's environment variables, `.env` files are ignored, and gitleaks found no leaks. We will rerun it before the release.

Self-audit questions. The server is not built yet, so each answer is the design, tested before release.

Question	Our answer
Can a student read another student's schedule?	No. Every query uses the user ID from the login token
Does any API route work without signing in?	No. Every /v1 route returns 401 without a token
Can the app read or write the database directly?	No. Row-level security blocks the public key
Are passwords stored by us?	No, Supabase Auth hashes and stores them
Do logs hold schedule data, emails, or tokens?	No. A unit test fails if one appears (EC-63)

Licensing summary

No package files exist yet, so this list comes from D1 Part 4 and D2, and we will rebuild it from the lock files. "Setup" means the version is chosen when the app folders are created.

Name	Version	License (SPDX)	Permissive or copyleft	Obligation
supabase-py, FastAPI, Pydantic, pdfplumber, OSMnx	2.34.0, 0.162.0, 2.14.3, 0.11.10, 2.1.1	MIT	Permissive	Keep the copyright and license notice
React Native, React, GitHub Actions checkout and setup-node	0.85.0, 19.3.0, v4	MIT	Permissive	Keep the copyright and license notice
Expo SDK, expo-notifications, supabase-js, MapLibre React Native	Setup	MIT	Permissive	Keep the copyright and license notice
Uvicorn, NetworkX, httpx	0.54.0, 3.7, setup	BSD-3-Clause	Permissive	Keep the notice; do not use the authors' names to endorse us
TypeScript	Setup	Apache-2.0	Permissive	Keep the license and NOTICE if redistributed
Python standard library	3.13.7	PSF-2.0	Permissive	Keep the PSF notice if redistributed
Supabase, Supabase Auth, PostgreSQL (hosted)	Set by Supabase	Apache-2.0, MIT, PostgreSQL	Permissive	Used under Supabase's terms; notices only if redistributed

Name	Version	License (SPDX)	Permissive or copyleft	Obligation
OpenStreetMap data	Downloaded in January	ODbL-1.0	Copyleft (data)	Credit "© OpenStreetMap contributors"; offer the method (below)
OpenFreeMap service, style, font, icons	Hosted	MIT (service), BSD-3-Clause and CC-BY-4.0 (style), OFL-1.1 (Noto Sans), CC0-1.0 (Maki)	Permissive; OFL-1.1 is weak copyleft (font only)	Show "© OpenMapTiles", which MapLibre adds
Expo Push, Apple Push, Firebase Messaging	Hosted	None (proprietary terms)	n/a	Used under their terms; public event information only
GetInvolvedUC categories	23 names	None (site terms)	n/a	Use only the category names

- **Our project's license:** MIT, added as a `LICENSE` file when we create the app folders, as we may share our code and a permissive license matches our dependencies.
- **Compatibility with every row:** Every code dependency is permissive, so MIT is compatible with all of them. Hosted services, map assets, and data stay outside our code and need only the credits above.
- **Copyleft items and what we decided:** OpenStreetMap data and the Noto Sans font. Our `building` and `walk_time` tables derive from OpenStreetMap, and the routes we show are produced works, so ODbL section 4.6 requires offering the derivative database or "the method of making the alterations." We offer the method: our MIT-licensed OSMnx import script on request. Every map shows the OpenStreetMap credit. OFL-1.1 applies only if we change or bundle Noto Sans, which we load unchanged. We rejected PyMuPDF (AGPL-3.0) for pdfplumber, because AGPL would require publishing our server's source.

Attribution list

The same list is in NOTICE.md.

- **Libraries:** Supabase, including its hosted PostgreSQL, Supabase Auth, supabase-py, and supabase-js (https://github.com/supabase), FastAPI (https://github.com/fastapi/fastapi), Pydantic (https://github.com/pydantic/pydantic), Uvicorn (https://github.com/Kludex/uvicorn), pdfplumber (https://github.com/jsvine/pdfplumber), OSMnx (https://github.com/gboeing/osmnx), NetworkX (https://github.com/networkx/networkx), React (https://github.com/facebook/react), React Native (https://github.com/facebook/react-native), TypeScript (https://github.com/microsoft/TypeScript), Python (https://www.python.org), Expo (https://github.com/expo/expo), httpx (https://github.com/encode/httpx), MapLibre React Native (https://github.com/maplibre/maplibre-react-native), OpenFreeMap (https://openfreemap.org), GitHub Actions (https://github.com/actions).
- **Code adapted from tutorials or other repositories:** None currently.
- **Datasets:** OpenStreetMap buildings and paths for Uptown West, downloaded in January with OSMnx into `building` and `walk_time`; ODbL-1.0 requires the credit and offering the derivative database or method. GetInvolvedUC's 23 category names, copied once into a migration under the site's terms. Volunteer schedule PDFs, collected with consent for testing only and deleted afterward.
- **Non-code assets:** None in the repository. The apps load from OpenFreeMap the OpenMapTiles style (BSD-3-Clause, CC-BY-4.0), the Noto Sans font (Noto Project Authors, OFL-1.1), and the Maki icons (Mapbox, CC0-1.0).

AI-use disclosure

- Syllabus AI policy: "Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course."

Tool	Used by	Task	Column	How verified
Claude	Laila	Assignment 3 ran essay to check for grammatical errors and gaps in the ask	Generally ok	Reviewed results and adjusted accordingly
Claude	Kaden and Laila	For Assignment 4: Ran user stories to verify validity and assist in adjusting to fit requirements	Generally ok	reviewed results and adjusted accordingly
Claude	Kaden	For Assignment 5: Showed completed diagram and version of md. Asked for adjustments to complete requirements	Generally ok	reviewed results and adjusted accordingly
Claude	Kaden	For Assignment 6: Drafted parts of the D1 document that our draft did not cover	Generally ok	Reviewed results and adjusted accordingly
Claude	Kaden	For Assignment 7: Drafted the D2 document and diagrams from the final version of D1 and his D2 draft.	Generally ok	Reviewed results and adjusted accordingly
Claude	Laila	Outlined Assignment 11, suggested commands for the git-history search and license inventory, explained how consent, access, and retention are usually handled for each data item, suggested wording for the Security, Licensing, and Attribution sections. Provided the code to search git history	Generally ok	Checked for inconsistencies and adjusted accordingly

We confirm that the architecture, data model, priorities, and design rationale were the team's own.

- Laila Raines
- Kaden Sawyer